

The Agency for the Protection of Personal Data has imposed an administrative fine in the amount of 15,000.00 euros (113,017.50 kuna) on the data controller, the hotel (i.e., the legal entity within which the subject hotel operates), due to the following established violations of the General Data Protection Regulation:

1. The data controller processed personal data of the respondents (hotel guests) to an excessive extent, specifically data regarding the security number of the credit card (CVC number), as well as copies of personal documents during the reservation of accommodation in the hotel via the hotel's online form and via email. There was no legal basis demonstrated for the processing of the CVC number of the credit card and the copy of the personal document, thereby violating Article 6, paragraph 1 of the General Data Protection Regulation. The hotel was not obligated to collect the CVC number from the credit cards of individuals who made a reservation for accommodation, given that the reservation was possible without providing this data.
2. The data controller did not clearly/transparently inform the respondents about the processing of their personal data through the document "General Terms and Conditions," which is available on the hotel's website, regarding the collection of personal data during the reservation of hotel accommodation via the online form and via email, which is contrary to the provisions of Article 13, paragraphs 1 and 2 of the General Data Protection Regulation. In this specific case, the hotel did not adequately provide notice about the processing of personal data to guests who reserved accommodation in the hotel, including information about the collection of data regarding the CVC number and the copy of the identification document. Considering the provisions of the regulations governing the protection of personal data, the hotel was obliged to inform the guest about what types of personal data it collects for what purpose, the legal basis for processing personal data, how personal data is used, who uses personal data, and what measures for the protection of personal data have been taken. All information regarding the processing of personal data had to be provided by the hotel in a concise, understandable, and easily accessible form, using clear and simple language, and it was obliged to inform the respondent of all rights that belong to them in accordance with the General Data Protection Regulation.
3. Furthermore, the form "Consent for the Use of Personal Data," which the data controller provides to inform respondents about the processing of their personal data when reserving accommodation via email, does not contain accurate or complete information, thereby acting contrary to the provisions of Article 13, paragraphs 1 and 2 of the General Data Protection Regulation.
4. By failing to take appropriate organizational and technical measures for the protection of personal data of respondents by the data controller, there was a violation of Article 32, paragraph 1 a) and d) and paragraph 4 of the General Data Protection Regulation. The data controller did not take appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among other things, the encryption of personal data and the implementation of processes for regular testing, assessment, and evaluation of the effectiveness of technical and organizational measures to ensure the security of processing.
5. By appointing the hotel manager as the data protection officer, the data controller acted contrary to the provisions of Article 38, paragraph 6 of the General Data Protection Regulation. Namely, the data protection officer may perform other tasks and duties; however, the data controller ensures that such tasks and duties do not lead to a conflict of interest. When appointing the data protection officer, the data controller had to be aware that there was a conflict of interest regarding the tasks and duties performed by the same. From the job description of the hotel manager, it is evident that they are largely responsible for making managerial decisions at the level of processing personal data, while on the other hand, as a data protection officer, they are obliged to monitor compliance with regulations governing the protection of personal data.

The Agency for the Protection of Personal Data received a complaint from a citizen who stated that when reserving accommodation in the subject hotel, confirmation of the reservation was requested by sending the CVC credit card number (via the form) through completely unprotected channels (via

email). Furthermore, the received complaint indicated that the potential guest was not informed about who has access to their personal data, i.e., the personal document that they were required to send at the request of the hotel in order to charge the credit card.

Namely, the subject hotel had three options for reserving accommodation – through a service provider, online reservation via the web form on the hotel's website, and via email, noting that reservations via the web form and email were only for booking, not for payment.

When reserving via the web form, it was necessary to enter the guest's personal data: first name, last name, email address, address, and financial data (card number, expiration date, CVC number, and cardholder's name), while for reservations via email, it was necessary to provide the aforementioned data and a copy of a valid identification document with a photograph, all to prevent misuse of the credit card by third parties, as claimed by the hotel.

In this case, considering the established violations, the Agency decided to impose an administrative fine due to the existence of a high risk to the rights and freedoms of the respondents, which the data controller was obliged to consider before the processing of personal data in question. Thus, it concerns a data controller whose business consists of processing personal data, and through the aforementioned actions, personal data was collected without the existence of an appropriate legal basis, and personal data that was collected was not...

necessary for the purpose for which they were collected from the respondents during the hotel accommodation reservation. Furthermore, the Agency believes that the imposition of a fine will lead to the data controller timely and appropriately fulfilling its obligations in the area of personal data protection.